



HCLS AI AGENT SUITE

Infrastructure & Adoption Review

A CIO / CISO / Director of Architecture perspective

THE VERDICT, UP FRONT Adopt as a governed accelerator to compress an SI-led build — not as a turnkey, validated product.

8 governed agents • AWS-native • 21 CFR Part 11 / GxP • GVP/E2B • HIPAA • FDA AI guidance (Jan 2025) • NIST AI RMF

Adopt it as a governed accelerator — not a finished product



What you are buying

A governance spine in code + 452 tests, AWS deployment runbooks, and a reference architecture (dual MCP gateway, in-VPC Bedrock, HITL, audit). It hands an SI a compliant, auditable starting point across 8 life-sciences workflows.



What you still build

Live Veeva / Argus / Medidata / QMS connectors, the reviewer UI, IdP federation, computer-system validation (CSV/CSA), and a penetration test. This is an engagement, not an install.



Why that is the right buy

It moves the hard, slow, risky part — governed access, HITL, audit, PHI masking, grounding — off your critical path. You compress months of SI build while keeping GxP / 21 CFR Part 11 accountability where it belongs: with you.

Recommendation: Approve a funded Phase-1 pilot on the lowest-decision-risk agents. Prove the gateway, audit, PHI masking, and HITL gate in production, then expand. Do not present this to the board as a product you can turn on next week.

The maturity ladder — positioned honestly

1

Documented

Architecture, workflow & compliance design written and reviewed

2

Demonstrated

Runs end-to-end in demo mode — deterministic fixtures, no API key (452 tests green)

3

Deployable

CloudFormation + Terraform + container contract pass CI; needs your AWS account + Bedrock

4

Production-ready

CSV/CSA validation, IdP, live connectors, pen test — the engagement

BRIGHT LINE — the engagement starts here



Real today

- Governance spine in code + 452 passing tests (gateway intersection, HITL, PHI masking, grounding, red-team) — no API key
- Empty-account-to-running CloudFormation quick-deploy: connector Lambdas + dual MCP gateway + native/container agent; Terraform parity
- Live reference path (Agent 02): real Bedrock + real HTTP connector, end-to-end; Strands + Step Functions waitForKeyToken HITL



A starting point, not finished

- Live connectors run on fixtures; production validation against Veeva / Argus / Medidata / QMS is yours
- AgentCore managed-gateway registration uses customer-supplied custom-resource placeholders; reviewer UI is an SI build
- No computer-system validation (CSV/CSA) package of its own, no SOC 2 / 3rd-party cert, no pen-tested production surface yet

Why a CISO or QA / regulatory lead can say yes

Governance-first: the controls are enforced in the gateway, outside the model — a prompt cannot turn them off.



Deny-by-default gateway

permitted(tool) = agent-grant $\cap$ user-entitlement. An agent can never exceed the human it acts for. Denies on a missing subject.



Framework-enforced HITL

Consequential actions block as PENDING_APPROVAL until a named, correctly-rolled reviewer binds identity (21 CFR Part 11 e-signature). Fails closed on timeout.



Tamper-evident audit

Append-only DynamoDB + S3 Object Lock WORM. Every ALLOW / DENY / PENDING / ERROR logged with lineage — Part 11 / ALCOA+ recordkeeping.



PHI / PII masking

Patient identifiers replaced with stable pseudonyms before any prompt or audit record. Stateless, runs before every gateway call.



Grounding verification

Every figure / entity in a regulated artifact must trace to the source corpus; grounding fails fast rather than asserting a hallucinated claim.



Fairness / diversity screen

Representativeness flags on proposed cohorts (FDA Diversity Action Plan posture); outcomes routed to human review — no automated adverse action.



Mapped to the life-sciences regulatory stack: 21 CFR Part 11 · GxP / ALCOA+ · GVP / ICH E2B(R3) · ICH E6(R3) GCP · HIPAA / de-identification · FDA AI guidance (Jan 2025) · EMA AI reflection paper · NIST AI RMF. The bright line — causality, reportability, what is submitted, CAPA disposition, patient eligibility, what reaches an HCP — is never decided by the agent.

Where it falls short — open risks today

Drawn directly from the deployment reference's own "gaps / what you must add" callouts. None are hidden; all are scoped.

STUB

Live connectors are fixtures

Veeva / Argus / Medidata / QMS run on deterministic fixtures; live validation against your systems is the engagement.

GAP

No CSV/CSA package yet

Computer-system validation (IQ/OQ/PQ) is the regulated production gate; the suite ships the design, not the executed package.

BUILD

Reviewer UI is your build

The HITL gate + queue ship; the screen a safety physician / writer / MLR reviewer uses to approve is a customer/SI build.

PART

AgentCore = placeholders

Managed Gateway & Runtime register via customer-supplied custom-resource Lambdas; portable gateway mode is the fallback.

PART

Observability to author

CloudWatch alarms / dashboards are per-environment; runbooks assume alarms and CloudTrail config you finalize.

PART

KB ingestion partial

Bedrock Knowledge Base ingestion IaC is a stub to build out per corpus (guidance, label, SOPs).

RISK

No cert · cost · accuracy

No SOC 2 / 3rd-party cert. Bedrock model cost & clinical accuracy must be validated against your data.

RISK

Change control is process

Prompt / model promotion change-control is framework-supported but operated by you under your quality system.

The questions to answer before you adopt



Data residency & GxP terms

Which Region? Does it meet data-localization and GxP data-integrity requirements? Are the controls Part 11-aligned in the vendor agreement?



DPA / BAA in place

Data-processing / business-associate agreement executed; vendor TPRM questionnaire signed off before any live patient or safety record is touched.



IdP federation

Can your IdP (Okta / Entra / Ping) express the reviewer roles (writer / safety physician / CRA / MLR)? Cognito ↔ IdP claim mapping is the most common readiness gap.



CSV / validation plan

Who owns the computer-system validation (IQ/OQ/PQ) and the validation lifecycle? Plan it before any GxP go-live.



Penetration test

Independent pen test of the deployed surface is a production-readiness gate — budget and schedule it before go-live.



Total cost of ownership

Bedrock inference + infra + SI delivery. Model the run-rate, not just the build; set Budgets + Cost Anomaly Detection on Bedrock.



Support & maintenance model

Who owns prompt/model change control, patching, and the managed-service SLA after the SI hands off?



Model-drift monitoring

Who watches grounding-failure rate, Guardrail block rate, and eval regression once it is live, and on what cadence?

Who owns what — platform, identity, security, data

 Developer / SI — deploys & maintains  Customer — sponsor IT / security / QA / regulatory  User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Platform & infrastructure — accounts, network, KMS, edge	—	C/I	R/A
Identity & access — IdP, Cognito federation, IAM roles	—	R/A	C/I
Security & compliance — GxP / Part 11 program, audits, pen test	C/I	R/A	C/I
Connectors & data — Veeva/Argus/Medidata integration, data quality, KB content	—	R/A	R/A

Where two parties show R/A, the control only holds if both act — e.g. the SI builds the connector; the sponsor provides credentials, approves scopes, and validates against the live, validated system.



Platform & infra

SI designs & deploys the VPC, KMS, and data plane per the templates; your cloud team approves network & key policy and owns the CMK. Edge hardening is finalized for production.



Identity & access

The IdP is yours — reviewer-role definitions (writer / safety physician / CRA / MLR) are sponsor policy. The SI implements the Cognito claim mapping; you own its accuracy.



Connectors & data

No connector points at a live system without your scope approval and a signed pilot SOW. Stale or wrong KB content is a sponsor risk; the SI implements change control.

Who owns what — model, validation, human-in-the-loop

 Developer / SI — deploys & maintains  Customer — sponsor IT / security / QA / regulatory  User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Model & guardrails — Bedrock access, Guardrails tuning, eval & change-control	—	R/A	R/A
Validation — CSV/CSA (IQ/OQ/PQ) testing & sign-off	—	R/A	R/A
HITL operations — approving consequential actions, reviewer roster	R/A	R/A	C/I
Reviewer UI / HITL handoff surface — build & operate	—	C/I	R/A

The human gate is the bright line. The SI builds it; the sponsor staffs it with qualified, correctly-roled reviewers (e.g. a safety physician for causality) — this cannot be delegated to the SI.



Model & guardrails

The SI recommends & implements per-agent Guardrail policy, prompt pinning, and the eval harness; your quality, safety & regulatory leadership approve it, and a named reviewer signs off promotions under change control.



Validation (CSV/CSA)

Computer-system validation is a production-readiness gate, not optional. The SI supports IQ/OQ/PQ during the engagement; you own the validation lifecycle and final sign-off in your quality system.



HITL operations

Consequential actions are approved by your named, correctly-roled reviewers (regulatory writer / safety physician / CRA / MLR). The SI runs the technical gate; you define what counts as “consequential.”

Who owns what — operations, change, training

 Developer / SI — deploys & maintains  Customer — sponsor IT / security / QA / regulatory  User — staff operating the agents

Responsibility domain	User	Customer (sponsor)	Developer / SI
Support & monitoring — alarms, dashboards, run-rate ops	—	C/I	R/A
Incident & deviation response — detection, containment, reporting	—	R/A	R/A
Change management — prompt / model upgrades, production promotion	C/I	R/A	R/A
Training & SOPs — staff enablement, the bright line, acceptable use	R/A	R/A	C/I

Operationally: the SI builds and runs the technical controls; the sponsor makes every regulated determination — deviation/CAPA, production sign-off, and SOP enforcement under its quality system.



Support & monitoring

Alarm thresholds, pager routing, and retention windows are sponsor-owned; the SI builds the dashboards and runs managed-service operations against your SLAs.



Incident & deviation

The SI executes the runbook, produces audit evidence, and notifies you fast; you make the regulated determination — deviation, CAPA, and any reportability to authorities — under your quality system.



Change & training

No prompt, model, or tool-grant change reaches production without your sign-off under change control. You own the SOPs and train staff on what the agent does and does not decide; the SI supplies capability docs.

What is still to be done



Live connectors

Validated adapters for live Veeva (RIM/Vault/CRM), Argus/Veeva Safety, Medidata, and QMS (TrackWise).



CSV / CSA package

Executed IQ/OQ/PQ validation and the traceability matrix under the sponsor's quality system.



KB ingestion pipeline

Bedrock Knowledge Base ingestion IaC built out from the stub per corpus (guidance, label, SOPs), grounding wired in.



Edge + observability IaC

CloudFront / WAF hardening and CloudWatch alarms + dashboards authored per environment.



Cedar / OPA policy export

Export the gateway authorization model to a standard policy engine for external review & reuse.



Penetration test

Independent pen test of the deployed surface — a production-readiness gate.



Reviewer UI

The HITL approve/reject surface that authenticates the reviewer and binds the e-signature into the record.



Production-readiness review

Full security & quality review, IdP integration tested, and sponsor acceptance sign-off.

Land low-risk, prove the controls, then expand





Phase gates: Each phase advances only when the prior clears its gate — clean audit trail, HITL gate exercised on real approvals, measured cycle-time, and a security/quality sign-off. Best demo entry point: Agent 02 (Pharmacovigilance) — the only agent with a live Bedrock + real-connector path you can run end-to-end. Safest document start: Agent 01.

Go / no-go criteria



GO if you can commit to...

- A funded SI-led engagement, not a product purchase
- Owning the GxP / Part 11 quality program, IdP, and reviewer roster
- A pilot scoped to Agents 01 / 02 / 03 / 08 with phase gates
- Budget for CSV/CSA validation + a pen test before go-live
- Validating Bedrock cost & clinical accuracy against your own data



NO-GO / wait if...

- You need a certified, turnkey product to switch on now
- There is no budget or partner for SI delivery & maintenance
- Your IdP cannot express the reviewer roles and there is no plan to fix it
- You expect the vendor to assume GxP / Part 11 accountability
- You cannot staff qualified HITL reviewers (e.g. a safety physician)

Recommendation: Approve a funded Phase-1 pilot on Agents 01 / 02 / 03 / 08. It compresses an SI-led build with a governance spine your CISO and QA/regulatory leadership can stand behind — while you keep GxP / Part 11 accountability and prove the controls in production before expanding.